Gallagher Command Centre / Controller 6000/7000

Gallagher Command Centre / Controller 6000/7000 — Firmware Attack Surface & Detection Brief

Scope: CVE and public-advisory (OSINT) research only — **no firmware or software has been acquired or extracted for this vendor.** Every finding below comes from public vulnerability disclosures (NVD, CISA ICS advisories, vendor PSIRT) and product documentation. CVE IDs listed in the Confirmed table were each independently re-verified against NVD/CISA/vendor records before inclusion; candidate IDs that could not be confirmed were dropped, not guessed.

Identity

Field	Value
Census / OUI string	`Gallagher Group Limited`
Operating company	Gallagher Group Limited (Gallagher Security division), Hamilton, New Zealand — privately held NZ manufacturer
OT devices (ARNG census)	17 across 4 states
Genuine OT vendor?	Yes
Purdue placement	Level 3 (site operations/management): Command Centre server and operator workstations — supervisory application tier, typically on a dedicated security VLAN adjacent to IT. Level 1 (basic control): Controller 6000/7000 and F-series fence controllers, which make local access/alarm decisions. Level 0 (field): T-series readers, I/O modules, door strikes/REX, and fence sensors/energizers. Net: a Level 0-1 field tier reporting up to a Level 2-3 Windows head-end.

Identity note. The census/OUI string maps directly to the real company Gallagher Group Limited (Hamilton, New Zealand). The OUI registration is held by the parent Gallagher Group; the devices actually on the wire are products of its Gallagher Security business unit (electronic access control and perimeter intrusion detection). This is NOT Arthur J. Gallagher & Co. (the unrelated US insurance broker), and not the Gallagher animal-management/fuel-systems division. No rebrand or acquisition indirection: the registered name, the OUI owner, and the operating company are the same entity, and the hardware bearing it is genuine physical-security OT gear (controllers, readers, fence energizers).

Product lines & OT relevance

Core electronic physical-access-control system (ePACS) and perimeter intrusion detection vendor. Gallagher gear controls doors, gates, turnstiles, man-traps and energized perimeter fences, and is widely deployed at

utilities, industrial plants, correctional, government and military/base-perimeter sites. For a National Guard OT-SOC these are cyber-physical control systems: a compromise opens/holds physical access or suppresses perimeter alarms, and the head-end commonly integrates to VMS/DVR, intrusion and BMS/HVAC. 17 devices across 4 states is consistent with controllers + readers + fence controllers reporting to one or more Command Centre servers.

- Gallagher Command Centre — access-control & security management platform (Windows server + operator workstations + REST API/SDK); the head-end/management layer
- Controller 6000 (superseded) and Controller 7000 — IP field access controllers that make offline/local access decisions and drive readers over RS-485 HBUS; firmware-bearing field devices
- F-Series monitored-pulse fence controllers / energizers (current F5/F6 single- and dual-zone; legacy F21/F22) for energized perimeter detection+deterrence; report to Command Centre over high-speed HBUS
- T-Series readers (T10/T11/T15/T20/T21) and reader/I-O modules on high-speed HBUS RS-485; support MIFARE DESFire, PIV/FICAM and mobile (BLE/NFC) credentials
- Intruder alarm functions and Remote Arming Terminals; high-level integrations to third-party VMS/DVR, intrusion and building systems
- High Security Controller 6000 variant (UK NPSA/CPNI CAPSS-approved) with authenticated/encrypted field comms

Attack surface

- Command Centre Server (Windows) exposes a proprietary controller-comms listener, an operator-workstation channel, and an HTTPS REST API/SDK plus high-level integrations (VMS/DVR, intrusion, BMS). Unauthenticated network reach to the server has allowed enumeration of access-card credentials (CVE-2020-16098, critical).
- Remote code execution path via inclusion of functionality from an untrusted control sphere affecting Command Centre Server and Workstations (CVE-2024-43690).
- Third-party DVR-integration credentials insufficiently protected and readable by any low-privilege authenticated operator (CVE-2024-21815).
- Over-privileged operator actions: improper output encoding lets an operator reconfigure controllers/hardware beyond their assigned privilege (CVE-2021-23205).
- Field controller: PIV credential verification can be bypassed at the Gallagher Controller (CVE-2021-23146), and the Diagnostics Service can be forced to a less-secure protocol (CVE-2023-46686).
- Credential/key hygiene: legacy card technologies (125 kHz prox, MIFARE Classic) remain supported and are cloneable; Gallagher issued a December 2020 advisory warning that a DESFire/MIFARE Plus default site key had been compromised — deployments that never diversified keys are exposed. OSDP/reader master keys have also been exposed in server memory (CVE-2021-23182, reported by Gallagher but not independently re-verified in this research).
- RS-485 HBUS field bus between controllers and readers is a physical/serial trust boundary at door/fence locations; physical tamper or bus tap is in scope for high-security sites.

Confirmed CVEs / advisories

Each row was re-verified against an authoritative record (URL given). This is the public disclosure history, not an exhaustive list.

CVE / advisory	Applies to	Summary	Source
`CVE-2020-16098`	Gallagher Command Centre server (the head-end this vendor's controllers report to); vendor	Unauthenticated network access to the Command Centre Server allows enumeration of access-card credentials, which can then be used to encode low-security cards.	https://nvd.nist.gov/vuln/detail/CVE-2020-16098
`CVE-2024-43690`	Gallagher Command Centre Server and Workstations; most recent high-severity RCE path again	Inclusion of functionality from an untrusted control sphere (CWE-829) in Command Centre Server and Workstations may allow remote code execution. CVSS 8.0 High.	https://cveawg.mitre.org/api/cve/CVE-2024-43690
`CVE-2024-21815`	Gallagher Command Centre Server; relevant where the ePACS integrates to a DVR/VMS, exposin	Insufficiently protected credentials (CWE-522) for third-party DVR integrations in Command Centre Server are accessible to any low-privilege authenticated opera	https://nvd.nist.gov/vuln/detail/CVE-2024-21815
`CVE-2021-23205`	Gallagher Command Centre; privilege-abuse path that reconfigures this vendor's field contr	Improper output encoding/escaping in Command Centre Server lets a Command Centre operator change the configuration of Controllers and other hardware beyond thei	https://nvd.nist.gov/vuln/detail/CVE-2021-23205
`CVE-2021-23146`	Gallagher Controller (the field access-control device itself, the firmware-bearing OT node	Incomplete comparison with missing factors in the Gallagher Controller allows an attacker to bypass PIV verification. CVSS 7.5 High. Affects 8.40<MR3, 8.30<MR3,	https://nvd.nist.gov/vuln/detail/CVE-2021-23146
`CVE-2023-46686`	Gallagher Command Centre Diagnostics Service; a protocol-downgrade weakness on this vendor	Reliance on untrusted inputs in a security decision lets a privileged user force the Gallagher Command Centre Diagnostics Service to use less-secure communicati	https://security.gallagher.com/Security-Advisories/CVE-2023-46686

Detection guidance

- Baseline and watch the controller-to-server channel: Gallagher controllers reach the Command Centre server over a proprietary encrypted TCP session (commonly TCP/1072 in Gallagher deployments — confirm the actual port from site config). Alert on any session to that listener originating outside the known controller VLAN/subnet, which is the exposure behind CVE-2020-16098.
- Restrict and monitor the Command Centre REST API/SDK (HTTPS, typically TCP/443 or a site-configured port) to known integration hosts only; alert on API auth failures and on controller/hardware configuration-change events (maps to CVE-2021-23205 abuse).

- Allowlist operator-workstation-to-server traffic to enumerated workstation hosts; treat any new host speaking the workstation or controller protocol as suspect.
- Log sources to pull: Command Centre audit/event log (operator actions and controller config changes), Windows Security/Application event logs and process/service-crash telemetry on the Command Centre server (RCE and DoS indicators — CVE-2024-43690), and Gallagher Diagnostics Service logs (protocol-downgrade attempts — CVE-2023-46686).
- Network segmentation/allowlisting: place the ePACS on its own VLAN and permit only server<->controllers, server<->named workstations, and server<->defined integration endpoints (VMS/DVR/BMS). Deny the controller subnet any route to the internet or general IT.
- Credential-layer detection: flag use of legacy/insecure card technologies and verify DESFire/MIFARE site keys are diversified (not the compromised December-2020 default); treat default-key sites as high priority.
- Inventory/version check: capture Command Centre version and controller firmware levels and compare against the fixed maintenance releases named in the CVEs (e.g., 9.10 MR2 / 9.00 MR4 for CVE-2024-43690) to find unpatched nodes.

Acquisition status

We currently hold NONE for this vendor and acquisition is gated. Gallagher does not publish firmware or Command Centre software for public download: the platform is distributed only to vetted Gallagher Channel Partners / certified installers through the Gallagher partner portal and requires licensing plus a partner account. Controller 6000/7000 and fence-controller firmware is pushed to field devices from the licensed Command Centre server (controllers auto-update over HBUS/IP), so there is no standalone public firmware image to pull. A time-limited Command Centre demo license exists at the discretion of a local Gallagher Business Development Manager. Only adjacent artifacts are open: public product/spec datasheets, and open-source component manifests for the Controller 6000/7000 and T-series readers hosted behind a shared login at security.gallagher.com/oss (these are OSS attribution files, not the device firmware). Net: obtaining real firmware would require partner/dealer-channel access or lawful vendor engagement; it is not available via open OSINT.

Notes

No CISA/ICS-CERT (ICSA) advisory was found for Gallagher in this research. That is expected: Gallagher Group is itself a CVE Numbering Authority and self-publishes advisories at security.gallagher.com/Security-Advisories/CVE-YYYY-NNNNN rather than routing through CISA ICS-CERT, so absence of an ICSA number is not absence of vulnerabilities. All six CVEs above were individually verified this session via the NVD REST API (services.nvd.nist.gov) with vendor field = Gallagher; the listed URLs are the canonical NVD detail records for the same CVE IDs. Candidate IDs seen in a secondary aggregator but NOT independently re-verified here (e.g., CVE-2021-23182 OSDP key-in-memory, CVE-2020-16100 DoS, CVE-2023-22363, CVE-2023-23570/23576) were deliberately excluded from cve_claims to avoid unverified entries; they can be confirmed on NVD/Gallagher if needed. The December 2020 Gallagher default DESFire/MIFARE-Plus key compromise is a key-hygiene advisory, not a CVE, and is captured under attack surface. TCP/1072 for controller comms is the commonly documented Gallagher default but was not re-verified this session — confirm against site configuration before building firewall rules.

Status

Item	State
Firmware/software acquired	**No** — OSINT/advisory only
Confirmed CVEs	6 (independently re-verified)
Behavioural baseline	None — no samples held
Next step	CISA/PSIRT deep pass; attempt firmware acquisition

Generated 2026-10-26 from the ot-vendor-briefs workflow (12 researchers + adversarial CVE verification). Device counts from the 2026-10-22 ARNG OT census.